

CMCMIS

Computerized Maintenance & Calibration Management Information System

Master Planning Document — v3

Project Definition · Module Architecture · Roles & RBAC
State Machines · Business Rules · FR/NFR
Tech Stack · System Architecture · Build Roadmap

*Prepared collaboratively for the
Industry-Grade Production Build (10-Week Sprint)*

Style: structured · table-heavy · flowchart-rich · beginner-to-advanced

Table of Contents

- Section 1 — Project at a Glance
- Section 2 — The 9-Module Architecture Map
- Section 3 — Role Model (5 Roles, Single-Tier Admin)
- Section 4 — Authorization & RBAC (3-Layer Model)
- Section 5 — Final Consolidated Permission Matrix
- Section 6 — Authentication Flow
- Section 7 — Critical State Machines
- Section 8 — Business Rules Catalogue
- Section 9 — Functional Requirements (MVP)
- Section 10 — Non-Functional Requirements
- Section 11 — Database Strategy & 70-Table Map
- Section 12 — Tech Stack (Frontend + Backend)
- Section 13 — System Architecture & Request Trace
- Section 14 — Express Middleware Pipeline
- Section 15 — Project Folder Structure
- Section 16 — Coding Conventions & API Standards
- Section 17 — MVP Scope vs Phase 2 Backlog
- Section 18 — 10-Week War Plan (Phased Timeline)
- Section 19 — Real-World End-to-End Walk-Through
- Section 20 — Constraints, Open Items, Quick Recap

Section 1 — Project at a Glance

1.1 The One-Sentence Version (Simple)

“CMCMIS is the system that knows where every instrument in our labs is, what state it’s in, when it needs calibration, who’s working on it, and what was done to it — for as long as the instrument exists.”

1.2 The Domain in 5 Words

REGISTER → CALIBRATE → MAINTAIN → REPAIR → RETIRE

Every record in CMCMIS is one event on one instrument’s journey through these 5 phases.

1.3 The Strategic Picture (Deep)

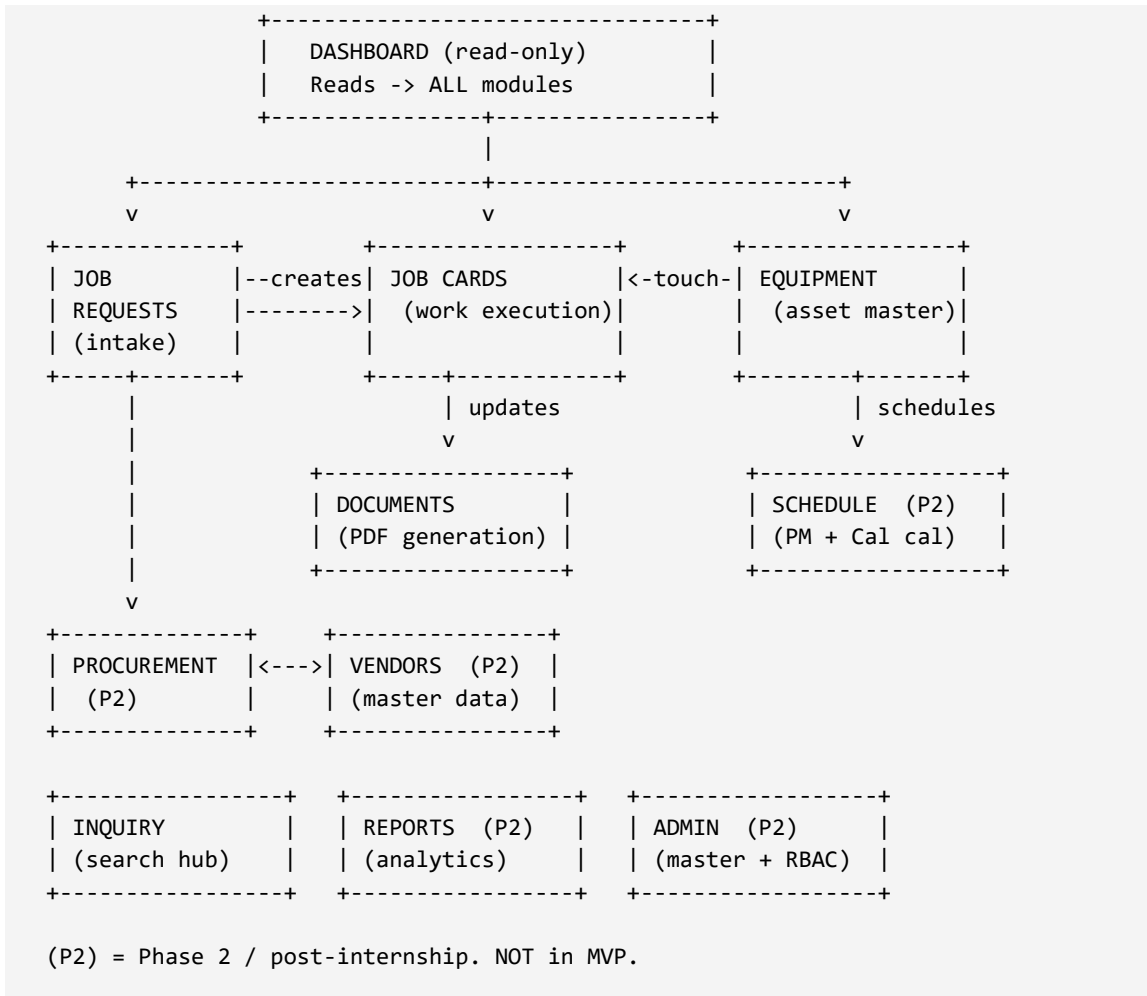
Layer	What Lives Here	Why It Matters
People	5 roles, hundreds of users	Wrong access = data corruption / compliance breach
Process	2 strict state machines	Wrong transitions = audit failures (ISRO-grade orgs cannot tolerate this)
Assets	Thousands of instruments + their full history	Lose history = lose calibration provenance = unsafe results
Money	POs, spares, vendor contracts (Phase 2)	Wrong PO chains = procurement audit issues
Knowledge	Reports, certificates, signatures	This IS the institutional memory

1.4 Engagement Context

Aspect	Decision
Organization context	ISRO SAC-like government / technical / defence-grade environment
Project status	Real organizational production system (NOT a prototype)
Owner	Solo Software-Developer intern (with AI pair)
Timeline	10 weeks for MVP; full go-live after testing + stakeholder approval
Deployment	Internal on-prem / private infra (NOT public cloud)
Existing system	~64 tables already exist with records — reviewed in Phase 1

Section 2 — The 9-Module Architecture Map

2.1 The Big Picture



2.2 Module Responsibility Matrix

#	Module	Owns (CRUD)	Reads From	Writes To	Primary Actors	MVP?
1	Dashboard	Nothing	All modules	Nothing	All roles	YES
2	Job Requests	job_requests	Equipment, Employees	Job Cards (on approval)	Normal User → Lab In-charge	YES
3	Job Cards	job_cards, tasks, observations	Job Requests, Equipment	Documents, Schedule, Equipment status	Lab Engineer, Lab In-charge	YES
4	Equipment	equipment,	Job Cards,	Schedule	All except	YES

		specs, cal_history	Procurement		View-Only	
5	Schedule	schedules (PM + Cal)	Equipment	Notifications, auto-Job Requests	Lab In-charge, Engineer	Phase 2
6	Procurement	purchase_orders, spare_parts	Vendors, Equipment	Equipment stock	Lab In-charge	Phase 2
7	Vendors	vendors	—	Procurement	Super Admin	Phase 2
8	Inquiry	Nothing (read-only)	Everything	—	All roles	YES
9	Reports	Nothing (read-only)	All modules	Export logs	Lab In-charge, Super Admin	Phase 2
10	Admin	Master data + Users + Roles	—	All master tables	Super Admin only	Phase 2 (RBAC actions live in MVP)

2.3 The Golden Rule of Data Flow

```

EQUIPMENT (source of truth)
  |
  v
JOB REQUEST (references equipment_id)
  |
  v
JOB CARD (references job_request_id + equipment_id)
  |
  v
DOCUMENT (references job_card_id, generated on demand)
  |
  v
EQUIPMENT.last_calibration_date <-- the ONLY back-write
                                   (and it goes through the state machine)

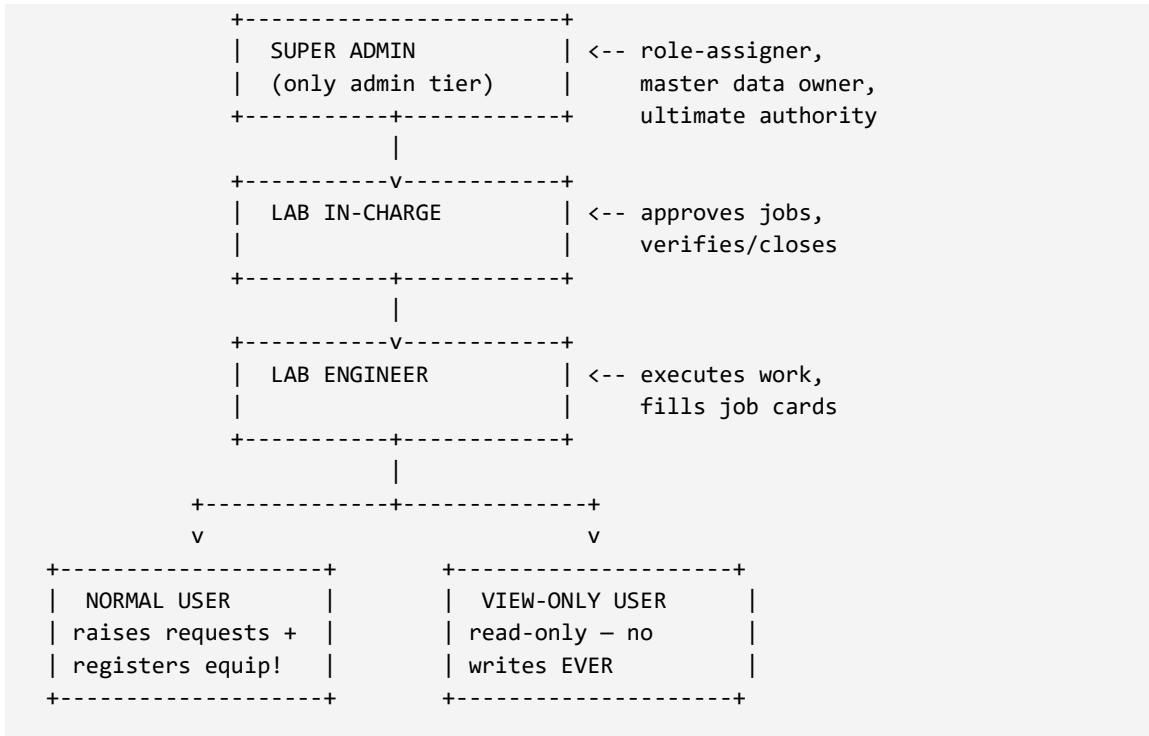
```

Why: If Job Cards could freely modify Equipment, audit trail breaks. ONE well-defined hook back-writes calibration metadata.

Section 3 — Role Model (5 Roles, Single-Tier Admin)

MAJOR CHANGE: The earlier 'Admin' role has been DELETED. Super Admin is now the single admin tier. The system has exactly 5 roles.

3.1 Role Hierarchy



3.2 Equipment Registration — Cross-Role Capability

All roles EXCEPT View-Only can register a new equipment. Even a Normal User can register. The verification (PENDING → ACTIVE) still requires Lab In-charge or Super Admin.

Section 4 — Authorization & RBAC (3-Layer Model)

4.1 Why 3 Layers, Not 2

USER	---	ROLE	---	PERMISSION	---	RESOURCE+ACTION
						+- "equipment:create"
				+- Granular toggle stored in DB		
		+- Role bundle (e.g. "Lab Engineer")				
+- Identity (employee_id)						

Layer	Real-world Example	Stored In
User	Employee #EMP1234 (Deep)	users
Role	Lab Engineer	roles + user_roles
Permission	job_card:update, equipment:read	permissions + role_permissions
Resource:Action	Checked at API middleware	Runtime check

4.2 Why This Matters

- 2-layer (User→Role) = you must redeploy every time business changes “who can do what”.
- 3-layer (User→Role→Permission) = Super Admin toggles a checkbox; behavior changes instantly. No redeploy.
- BR-RBAC-03: code NEVER checks by role name. Always by permission. This is the contract.

Section 5 — Final Consolidated Permission Matrix

This replaces every prior permission matrix in this conversation. One source of truth.

5.1 Authentication & Identity

Resource:Action	Normal	View-Only	Lab Engr	Lab In-charge	Super Admin
auth:login	YES	YES	YES	YES	YES
auth:logout	YES	YES	YES	YES	YES
auth:refresh-token	YES	YES	YES	YES	YES
me:read (own profile)	YES	YES	YES	YES	YES

5.2 User & Role Management (Super Admin only)

Resource:Action	Normal	View-Only	Lab Engr	Lab In-charge	Super Admin
user:read-list	NO	NO	NO	NO	YES
user:role-assign	NO	NO	NO	NO	YES
user:activate / user:deactivate	NO	NO	NO	NO	YES

5.3 Equipment (equipment:create open to ALL except View-Only)

Resource:Action	Normal	View-Only	Lab Engr	Lab In-charge	Super Admin
equipment:read-list	YES	YES	YES	YES	YES
equipment:read-detail	YES	YES	YES	YES	YES
equipment:create (NEW BEHAVIOUR)	YES	NO	YES	YES	YES
equipment:update	NO	NO	YES	YES	YES
equipment:verify (PENDING -> ACTIVE)	NO	NO	NO	YES	YES
equipment:delete (hard)	NO	NO	NO	NO	YES
equipment:condemn (status flip)	NO	NO	NO	YES	YES

5.4 Job Requests

Resource:Action	Normal	View-Only	Lab Engr	Lab In-charge	Super Admin
job_request:create	YES	NO	YES	YES	YES
job_request:read-own	YES	YES	YES	YES	YES

job_request:read-all	NO	YES	YES	YES	YES
job_request:approve	NO	NO	NO	YES	YES
job_request:reject	NO	NO	NO	YES	YES
job_request:assign-engineer	NO	NO	NO	YES	YES

5.5 Job Cards (Super Admin + Lab In-charge full rights)

Resource:Action	Normal	View-Only	Lab Engr	Lab In-charge	Super Admin
job_card:read-list	NO	YES	YES	YES	YES
job_card:read-detail	NO	YES	YES	YES	YES
job_card:start-work	NO	NO	YES (own)	YES	YES
job_card:update-tasks	NO	NO	YES (own)	YES	YES
job_card:complete	NO	NO	YES (own)	YES	YES
job_card:verify-close	NO	NO	NO	YES	YES
job_card:reopen	NO	NO	NO	YES	YES
job_card:generate-pdf	NO	YES	YES	YES	YES

5.6 Dashboard & Inquiry

Resource:Action	Normal	View-Only	Lab Engr	Lab In-charge	Super Admin
dashboard:view	YES	YES	YES	YES	YES
inquiry:search-vendors	YES	YES	YES	YES	YES
inquiry:search-products	YES	YES	YES	YES	YES
inquiry:search-job-cards	NO	YES	YES	YES	YES
inquiry:search-instruments	YES	YES	YES	YES	YES

5.7 Master Data (Super Admin only — Phase 2 build)

Resource:Action	Normal	View-Only	Lab Engr	Lab In-charge	Super Admin
master:employees:manage	NO	NO	NO	NO	YES
master:vendors:manage	NO	NO	NO	NO	YES
master:equipment-types:manage	NO	NO	NO	NO	YES
master:divisions:manage	NO	NO	NO	NO	YES
master:lookup-values:manage	NO	NO	NO	NO	YES

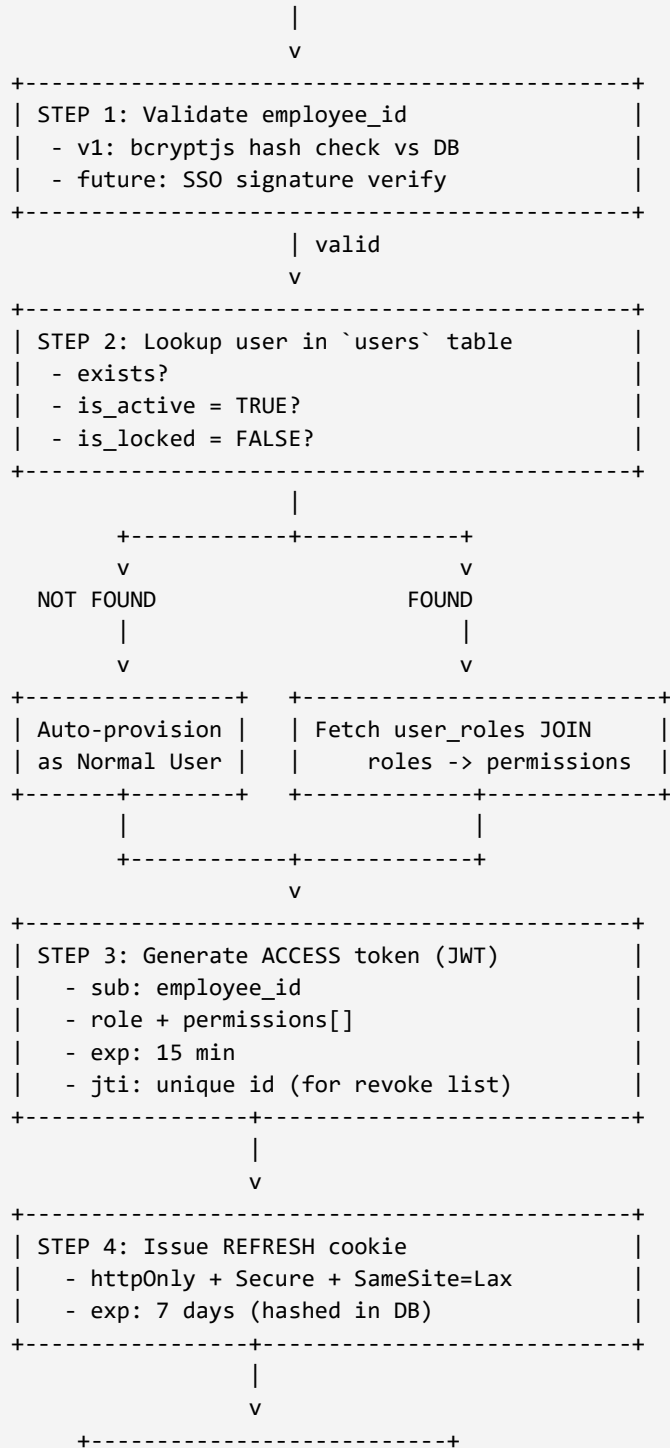
5.8 Audit & Logs

Resource:Action	Normal	View-Only	Lab Engr	Lab In-charge	Super Admin
audit_log:read	NO	NO	NO	NO	YES
export:trigger (PDF / future Excel)	NO	NO	YES	YES	YES

Section 6 — Authentication Flow

6.1 Login Flow (v1: employee_id + password; SSO-ready)

User submits credentials OR SSO returns identity assertion (future)



```

| Authenticated session |
| -> write login_audit row |
+-----+

```

6.2 Session Envelopes (Three Concentric Timers)

```

+=====+
| REFRESH TOKEN MAX (7 days, absolute) |
| +-----+ |
| | 60-MIN INACTIVITY WINDOW (sliding) | | | |
| | +-----+ | |
| | | 15-MIN JWT ACCESS TOKEN (short-lived) | | |
| | | refreshed silently on each authed API call | | |
| | +-----+ | |
| | resets on every authenticated request | |
| +-----+ |
| hard expiry; user MUST re-login |
+=====+

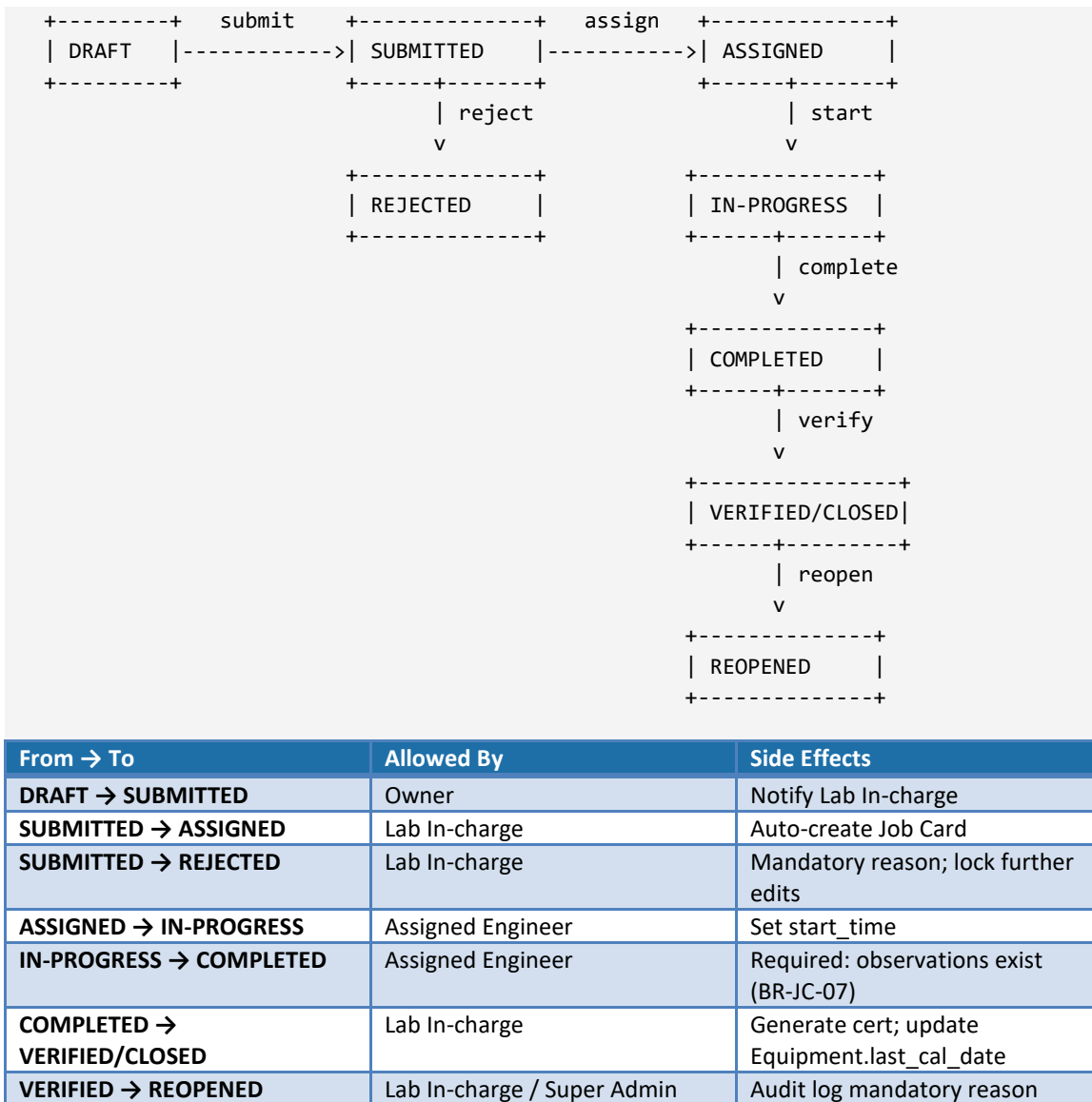
```

6.3 First Super Admin Bootstrap

- Seeded via DB migration on first deploy (NOT manual SQL).
- Env var: SUPER_ADMIN_EMPLOYEE_IDS (comma-separated, at least 2).
- Migration inserts users + user_roles (SUPER_ADMIN) + audit_log 'BOOTSTRAP' rows.
- First login forces password reset (password_must_change = TRUE).

Section 7 — Critical State Machines

7.1 Job Request Lifecycle



7.2 Equipment Lifecycle (with NEW PENDING_VERIFICATION state)

NEW: All equipment registrations now START at PENDING_VERIFICATION. Only Lab In-charge or Super Admin can flip to ACTIVE (BR-EQP-10).

[PENDING_VERIFICATION] --verify by InC/SA--> [ACTIVE]

|

```

[ACTIVE]                                     +---> [UNDER_CALIBRATION] -->
                                           |
                                           |
[OUT_OF_TOLERANCE] --> [UNDER_REPAIR] --> [ACTIVE] +--->
                                           |
                                           +---> [UNDER_REPAIR] --> [ACTIVE]
                                           |
                                           +---> [QUARANTINED] -->

[CONDEMNED/RETIRED]    (terminal)

```

7.3 Implementation Pattern (Single Choke-point)

```

// ONE function per entity. Single source of truth.
function transitionJobRequest(currentState, action, actor) {
  const allowed = ALLOWED_TRANSITIONS[currentState]?.[action];
  if (!allowed) throw new Error('Illegal transition');
  if (!actor.hasPermission(allowed.permission)) throw new Error('Forbidden');
  return { newState: allowed.to, sideEffects: allowed.effects };
}

```

*Why this matters: no developer writes raw UPDATE statements for status anywhere. Every transition writes to *_status_history automatically. Audit trail is free.*

Section 8 — Business Rules Catalogue

*These are the contract between the business and the code. Every API endpoint enforces them.
36+ rules across 9 categories.*

8.1 BR-AUTH — Authentication & Identity

ID	Rule
BR-AUTH-01	Login is by employee_id only (not email/username).
BR-AUTH-02	User must exist in org's employee directory — no self-registration.
BR-AUTH-03	Authenticated user with no role → defaults to Normal User.
BR-AUTH-04	Sessions expire after 60 minutes of inactivity. Refresh token valid 7 days.
BR-AUTH-05	First Super Admin seeded via DB migration using SUPER_ADMIN_EMPLOYEE_IDS env var. Seed at least 2.
BR-AUTH-06	All login attempts (success + failure) are logged.
BR-AUTH-07	Deactivated user (status = INACTIVE) cannot log in but history is preserved.

8.2 BR-RBAC — Authorization

ID	Rule
BR-RBAC-01	Only Super Admin can assign/change a user's role.
BR-RBAC-02	A user has exactly ONE primary role at a time (no multi-role in v1).
BR-RBAC-03	Permissions derived: User → Role → Permissions. NEVER check by role name.
BR-RBAC-04	Sidebar items and routes filtered by permissions, not role names.
BR-RBAC-05	Every API endpoint enforces permission check at controller layer.
BR-RBAC-06	View-Only users can read but cannot trigger any write operation.
BR-RBAC-07	Role changes take effect on next login OR token refresh.

8.3 BR-EQP — Equipment

ID	Rule
BR-EQP-01	Every equipment has a unique serial number system-wide.
BR-EQP-02	Equipment must belong to T&ME or F&PE category.

BR-EQP-03	F&PE may have NO calibration frequency (optional).
BR-EQP-04	T&ME MUST have calibration frequency (months).
BR-EQP-05	next_cal_due_date = last_cal_date + calibration_frequency_months.
BR-EQP-06	Status transitions follow the equipment state machine.
BR-EQP-07	Hard DELETE = Super Admin only. CONDEMN = Lab In-charge OR Super Admin.
BR-EQP-08	Search is case-insensitive across serial, model, manufacturer, type.
BR-EQP-09	NEW. Every registration captures registered_by + verified_by + timestamps.
BR-EQP-10	NEW. New equipment defaults to PENDING_VERIFICATION; verify by Lab In-charge / Super Admin → ACTIVE.

8.4 BR-JR — Job Requests

ID	Rule
BR-JR-01	Must reference existing equipment (or trigger registration).
BR-JR-02	Job type ∈ {Calibration, Repair, Registration}.
BR-JR-03	User can save as DRAFT before submitting.
BR-JR-04	Once SUBMITTED, only Lab In-charge can change state.
BR-JR-05	Submitted request must be assigned to a Lab Engineer before becoming a Job Card.
BR-JR-06	'submitted by' auto-filled from current user — not overridable.
BR-JR-07	High-priority repairs appear at top of Lab In-charge queue.
BR-JR-08	Rejection requires mandatory reason (free text + reason code).

8.5 BR-JC — Job Cards

ID	Rule
BR-JC-01	Auto-created when a request is approved + assigned.
BR-JC-02	Lifecycle: ASSIGNED → IN-PROGRESS → COMPLETED → VERIFIED/CLOSED.
BR-JC-03	Only the assigned engineer can mark IN-PROGRESS or COMPLETED.
BR-JC-04	Only Lab In-charge can verify/close.
BR-JC-05	Closed job can only be REOPENED by Lab In-charge with reason.
BR-JC-06	Tasks are configurable per job type.
BR-JC-07	Calibration cards require before-reading + after-

	reading + environment before COMPLETED.
BR-JC-08	Job card history is append-only — immutable state transition log.

8.6 BR-PDF, BR-AUD, BR-VIS, BR-MASTER

ID	Rule
BR-PDF-01	PDFs generated on demand from current DB state. Nothing stored.
BR-PDF-02	Job card PDF: header, equipment info, tasks, observations, signatures, date.
BR-PDF-03	Calibration cert PDF: equipment, standards, readings, environment, uncertainty, valid-until.
BR-PDF-04	All PDFs include generation timestamp + footer + record ID.
BR-AUD-01	Every write on critical tables is logged in audit_logs.
BR-AUD-02	Audit log captures who, what, when, before/after, IP, user-agent.
BR-AUD-03	Exports logged with user + record IDs accessed.
BR-AUD-04	Sensitive fields filtered from API responses based on permission.
BR-AUD-05	HTTPS in prod. JWT in Authorization header. Refresh in httpOnly cookie.
BR-VIS-01	Normal User sees only their own job requests.
BR-VIS-02	Lab Engineer sees all jobs assigned to them + the queue.
BR-VIS-03	Lab In-charge and above see all jobs and equipment.
BR-VIS-04	View-Only sees all data, performs no actions.
BR-MASTER-01	NEW. All master-data CRUD is Super Admin only.

Section 9 — Functional Requirements (MVP)

45 FRs across 6 MVP modules. 44 MUST + 1 SHOULD.

9.1 FR-A — Auth & RBAC Module

FR ID	Description	Priority
FR-A-01	Login screen accepts employee_id + password	MUST
FR-A-02	Successful login returns JWT + sets refresh cookie	MUST
FR-A-03	Logout clears tokens and invalidates session	MUST
FR-A-04	Protected routes redirect to login when unauthenticated	MUST
FR-A-05	Sidebar items render based on user's permission set	MUST
FR-A-06	Super Admin can view list of all users + their roles	MUST
FR-A-07	Super Admin can assign/change a user's role	MUST
FR-A-08	Super Admin can activate/deactivate a user	MUST
FR-A-09	Backend exposes GET /me returning current user + permissions	MUST
FR-A-10	Token refresh endpoint silently extends session	MUST

9.2 FR-E — Equipment Module

FR ID	Description	Priority
FR-E-01	List equipment with pagination, search, filter (type, status)	MUST
FR-E-02	View equipment detail page with specs, cal history, linked jobs	MUST
FR-E-03	Register new equipment (available to all roles except View-Only)	MUST
FR-E-04	Edit equipment details (specs, status)	MUST
FR-E-05	Color-code calibration due dates (green/yellow/red)	MUST
FR-E-06	Show equipment's calibration history timeline	MUST
FR-E-07	Search equipment by serial, model, manufacturer	MUST

FR-E-08	Soft-delete (status = CONDEMNED) for non-super-admins	MUST
FR-E-09	NEW. Lab In-charge / Super Admin verify equipment (PENDING → ACTIVE)	MUST

9.3 FR-JR — Job Request Module

FR ID	Description	Priority
FR-JR-01	List job requests with filters (type, status, my requests vs all)	MUST
FR-JR-02	Create job request form (multi-section, progressive disclosure)	MUST
FR-JR-03	Save as draft	MUST
FR-JR-04	Submit triggers state transition to SUBMITTED	MUST
FR-JR-05	View request detail with full info + state history	MUST
FR-JR-06	Lab In-charge can approve / reject with reason	MUST
FR-JR-07	Approval triggers automatic Job Card creation	MUST
FR-JR-08	Assignment dropdown shows lab engineers with current workload	SHOULD

9.4 FR-JC — Job Card Module

FR ID	Description	Priority
FR-JC-01	List job cards with filter (status, assigned-to-me, all)	MUST
FR-JC-02	View job card with horizontal status stepper	MUST
FR-JC-03	Task checklist (configurable per job type)	MUST
FR-JC-04	Observations & readings log (free text + structured)	MUST
FR-JC-05	Engineer can transition state (Start work, Mark complete)	MUST
FR-JC-06	Lab In-charge can Verify/Close or Reopen	MUST
FR-JC-07	Generate PDF of job card (on-demand download)	MUST
FR-JC-08	State history visible as timeline	MUST

9.5 FR-D — Dashboard

FR ID	Description	Priority
FR-D-01	Role-aware KPI widgets (different per role)	MUST
FR-D-02	Calibration due alerts (next 30 days + overdue)	MUST
FR-D-03	Engineer workload bar chart (for Lab In-charge)	MUST
FR-D-04	Equipment status pie chart	MUST
FR-D-05	Recently updated jobs table	MUST
FR-D-06	Quick actions: Raise request, Add equipment (permission-gated)	MUST

9.6 FR-I — Inquiry

FR ID	Description	Priority
FR-I-01	4-tab interface (Vendor, Product, Job Card, Instrument)	MUST
FR-I-02	Real-time search with debounce	MUST
FR-I-03	Result tables with drill-down link to full record	MUST
FR-I-04	Empty-state messages when no results	MUST

Section 10 — Non-Functional Requirements

Category	Requirement	Target
Performance	Initial page load (cold)	< 3 sec on intranet
Performance	API response (95th percentile)	< 500 ms
Performance	List pagination	25 default, 100 max
Security	Password hashing	bcrypt $\geq$ 10 rounds
Security	JWT access lifetime	15 min
Security	Refresh token lifetime	7 days, httpOnly cookie, SameSite=Lax
Security	SQL injection defence	Parameterized queries everywhere
Security	XSS	React auto-escape + CSP header
Security	CSRF	SameSite cookies + CSRF token on /auth/refresh
Reliability	Server uptime (post go-live)	99% during business hours
Reliability	DB connection pool	10–20 connections
Usability	Max clicks to any feature	$\leq$ 3
Usability	Keyboard shortcuts	On power-user screens
Usability	Responsive viewport	1280–1920 primary; graceful to 768
Audit	Every state-changing op logged	Yes
Audit	Audit log retention	Indefinite (until specified)
Maintainability	Code style	ESLint + Prettier (enforced via husky)
Maintainability	Folder structure	routes / controllers / services / models / utils
Maintainability	API versioning	/api/v1/... from day 1
Compatibility	Browsers	Chrome, Edge, Firefox (latest 2 versions)

Section 11 — Database Strategy & 70-Table Map

REALITY CHECK: ~64 tables already exist with records. CMC MIS does NOT start on a blank slate — we refactor/extend existing schema in Phase 1.

TOMORROW I WILL PROVIDE YOU ALL THE DB RELATED INSTRUCTIONS.

Section 12 — Tech Stack (Frontend + Backend)

12.1 Frontend Stack (React 18 + Vite + Tailwind v3)

#	Concern	Library	Why
1	Build	vite	Fast HMR, modern
2	Framework	react@18	Locked
3	Routing	react-router-dom v6	SPA standard
4	State (local)	useState / useReducer	Built-in
5	State (global UI)	zustand	~1KB, no boilerplate
6	Server state	@tanstack/react-query	Cache/refetch/mutations
7	HTTP	axios	Interceptors for auth/refresh
8	Forms	react-hook-form + zod	Performant + schema shared with BE
9	UI primitives	Custom on Tailwind	Avoids shadcn/MUI lock-in
10	Icons	lucide-react	Tree-shakable
11	Charts	recharts	Dashboard widgets
12	Date	dayjs	Symmetric with backend
13	Toasts	sonner	Lightweight
14	Styling	tailwindcss v3	Locked
15	Lint/Format	eslint + prettier + husky + lint-staged	Pre-commit

12.2 Backend Stack (Node + Express 4)

#	Concern	Library	Ver	Why
1	Web framework	express	^4.x	Stable, ubiquitous
2	DB driver	mysql2/promise	^3.x	Fastest MySQL driver
3	Validation	zod	^3.x	Single source of truth (FE+BE share)
4	Auth tokens	jsonwebtoken	^9.x	Industry standard
5	Password hash	bcryptjs	^2.x	Pure-JS, no native build pain
6	Logger	pino + pino-pretty	^8.x	Faster than Winston, JSON
7	Env loader	dotenv	^16.x	Standard
8	Env validation	envalid	^8.x	Fail at boot if env missing
9	Date	dayjs	^1.x	Symmetric with frontend
10	PDF	pdfkit	^0.14.x	Programmatic, no Chromium
11	Rate limit	express-rate-limit	^7.x	In-memory,

				sufficient v1
12	Security	helmet	^7.x	OWASP-friendly defaults
13	CORS	cors	^2.x	Standard
14	Process mgr	pm2	latest	Cluster mode, restarts, logs
15	Lint/Format	eslint + prettier + husky + lint-staged	latest	Pre-commit

12.3 The Three Big Architectural Wins

- Schema symmetry — zod on BOTH frontend and backend → one definition, two enforcers.
- Date symmetry — dayjs on BOTH sides → no timezone/format drift on BR-EQP-05 math.
- On-prem friendly — pdfkit (no Chromium), pm2 (no systemd quirks), no Redis/SMTP/object-storage dependencies.

12.4 Pending Stack Additions Awaiting Your OK→ OKAY BY ME AS AGREED

#	Addition	Why
1	cookie-parser (BE)	Needed to read httpOnly refresh cookie
2	compression (BE)	gzip/brotli — helps NFR p95 < 500ms
3	CSRF token on /auth/refresh	NFR mandates; custom double-submit token recommended
4	@tanstack/react-table (FE)	Headless table for equipment/job lists
5	@tailwindcss/forms (FE)	Sane form defaults
6	vitest + supertest	Unit + API testing for auth + state machines

PLEASE USE THIS ABOVE TABLE THINGS TECH ALSO.

Section 13 — System Architecture & Request Trace

13.1 Runtime Architecture

```
+-----+
| DESKTOP / LAPTOP BROWSER (NO MOBILE) |
| React 18 + Vite + Tailwind           |
|   Routes -> React Router              |
|   Server state -> TanStack Query       |
|   Forms -> React Hook Form + zod      |
|   HTTP -> axios (interceptor attaches JWT) |
+-----+
|                                     |
|   | HTTPS (JWT + httpOnly refresh)   |
|   v                                 |
+-----+
| NODE + EXPRESS API SERVER (on-prem)  |
| Middleware: helmet > cors > compression > json > cookies |
|               > pino > rate-limit > auth > authorize > scope |
|               > validate(zod) > controller                  |
| Service layer: state-machine transition()                    |
|                   pdfkit cert generator                     |
|                   audit-log helper                           |
| Data access: mysql2/promise pool, parameterized SQL         |
+-----+
|                                     |
|   v                                 |
+-----+
| MySQL 8.x (existing on-prem; phpMyAdmin admin) |
| ~70 tables (existing 64 + new) · InnoDB · utf8mb4 |
| FK + CHECK constraints · indexes per dashboard/inquiry |
+-----+

NOT IN MVP: Redis · SMTP · S3/Object store · SSO/AD
```

13.2 End-to-End Request Trace (Equipment Register)

```
Lab Engineer fills equipment register form
-> react-hook-form + zod validates on submit (no network if invalid)
-> @tanstack/react-query mutation calls axios.post('/api/v1/equipment')
-> axios interceptor attaches Bearer JWT
----- NETWORK BOUNDARY -----
-> helmet (headers) > cors > compression > express.json > cookie-parser
-> pino logs request meta
-> express-rate-limit (auth routes only)
-> authenticate (jsonwebtoken verify)
-> authorize ('equipment:create' permission check)
-> rowLevelScope (no-op for create)
-> validate(zod) re-checks body
-> equipmentController.create
-> equipmentService.create:
```

```
- dayjs.add for next_cal_due_date
- state machine: status = PENDING_VERIFICATION
- audit_log row
-> mysql2 transaction: INSERT equipment + INSERT audit_log
-> 201 Created + JSON body
-> pino logs response status + duration
----- NETWORK BOUNDARY -----
-> react-query invalidates 'equipment-list' cache
-> sonner: 'Equipment registered. Pending verification.'
-> router navigates to detail page
```

Section 14 — Express Middleware Pipeline

```
incoming request
  |
  v
+-----+
| 1. helmet()           <- security headers |
| 2. cors(orgAllowlist) <- reject foreign origins |
| 3. compression()     <- gzip responses |
| 4. express.json({limit}) <- parse JSON body |
| 5. cookie-parser()    <- parse refresh cookie |
| 6. pino-http()        <- log request meta |
| 7. rateLimit(login)   <- only on auth routes |
| 8. authenticate()    <- JWT verify |
| 9. authorize(perm)    <- RBAC check |
| 10. rowLevelScope()   <- BR-VIS WHERE clause |
| 11. validate(zodSchema) <- input validation |
| 12. controller       <- business handler |
| 13. errorHandler()   <- centralized errors |
+-----+
  |
  v
outgoing response
```

Section 15 — Project Folder Structure

```
cmcmis-simplified/
|
+-- backend/
|   +-- src/
|       |   +-- config/          (db.js, env.js, logger.js, jwt.js)
|       |   +-- middleware/      (authenticate, authorize, rowLevelScope,
|       |   |                   validate, errorHandler)
|       |   +-- modules/
|       |       |   +-- auth/      (routes, controller, service, schema)
|       |       |   +-- users/
|       |       |   +-- equipment/
|       |       |   +-- jobRequests/
|       |       |   +-- jobCards/
|       |       |   +-- dashboard/
|       |       |   +-- inquiry/
|       |       |   +-- audit/
|       |       +-- stateMachines/ (jobRequest.fsm.js, equipment.fsm.js)
|       |       +-- pdf/           (jobCard.pdf.js, calibrationCert.pdf.js)
|       |       +-- utils/
|       |       +-- server.js
|   +-- db/
|       |   +-- migrations/      (numbered .sql files)
|       |   +-- seeds/           (roles, permissions, super admins)
|       |   +-- schema.sql
|   +-- tests/
|   +-- .env.example
|   +-- ecosystem.config.js (pm2)
|   +-- package.json
|
+-- frontend/
|   +-- src/
|       |   +-- api/              (axios client + per-module hooks)
|       |   +-- components/      (Button, Input, Table, Modal,
FormField)
|       |   +-- features/         (auth, equipment, jobRequests,
jobCards,
|       |   |                   dashboard, inquiry)
|       |   +-- layouts/         (AppLayout, AuthLayout)
|       |   +-- lib/             (authContext, permissions,
formatters)
```

```
| | +-- pages/          (thin route components)
| | +-- schemas/       (zod schemas – shared with BE)
| | +-- stores/        (zustand)
| | +-- router.jsx
| | +-- main.jsx
| +-- public/
| +-- tailwind.config.js
| +-- vite.config.js
| +-- package.json
|
+-- docs/
|   +-- ERD.md
|   +-- rbac-matrix.md
|   +-- state-machines.md
|   +-- business-rules.md
+-- .gitignore
+-- .editorconfig
+-- README.md
+-- package.json    (monorepo root)
```

Section 16 — Coding Conventions & API Standards

Concern	Convention
API base	/api/v1/...
HTTP verbs	REST: GET / POST / PATCH / DELETE
Response shape (success)	{ data, meta }
Response shape (error)	{ error: { code, message, details } }
Status codes used	200 / 201 / 204 / 400 / 401 / 403 / 404 / 409 / 422 / 429 / 500
Pagination	?page=1&limit=25 (max 100)
Filtering	?status=ACTIVE&type=TME (whitelisted per endpoint)
Sorting	?sort=-created_at,name (- prefix = DESC)
Naming (DB)	snake_case, plural tables, id PKs, *_id FKs
Naming (JS)	camelCase vars/functions, PascalCase components/classes
Naming (files)	kebab-case.js or PascalCase.jsx for React components
Errors	Throw typed errors → centralized handler → standard response
Logs	Structured JSON via pino; never console.log
Commits	Conventional Commits (feat / fix / chore / ...)
Branches	feature/*, fix/*, chore/* from main

Section 17 — MVP Scope vs Phase 2 Backlog

17.1 MVP (10 weeks) — Signed Off

- Auth + RBAC (login, session, role loading, permissions, protected routes, SSO-ready)
- Equipment master + register + verify flow
- Job Requests (form, listing, lifecycle)
- Job Cards (tasks, observations, sign-off)
- Dashboard (role-aware KPIs, alerts, widgets)
- Inquiry (search hub — vendors, products, job cards, instruments)
- PDF generation (download/generate only — no storage)
- Audit logs (basic, all state changes)
- Responsive UI (desktop + laptop; 1280–1920 primary)
- Row-level visibility (per BR-VIS rules)
- Optimized SQL with pagination + connection pool

17.2 Phase 2 — Post-Internship Backlog

- Schedule module (PM + Calibration calendar)
- Procurement (POs + spares)
- Reports (analytics + exports)
- Admin master-data CRUD UI
- Notifications (in-app feed)

17.3 Explicitly NOT in MVP

Item	Decision
SSO / Active Directory integration	Architecture SSO-ready, integration deferred
Email / SMTP	Out of scope until specified
Redis / caching layer	MySQL + pagination + pool is enough
File storage	PDFs generated + downloaded only, never stored
Backup infrastructure	Out of our scope
Mobile / tablet UI	Desktop + laptop only (responsive within range)
Barcode / QR	Not in scope
NABL / ISO 17025 / AS9100 specifics	Deferred — user will instruct
Calibration cert template format	Deferred — user will instruct
Notification channels (email/in-app/SMS/push)	Deferred — user will instruct

Section 18 — 10-Week War Plan (Phased Timeline)

Week	Phase	Deliverables
1	Phase 0 — Foundation	Repo scaffolding · ESLint/Prettier · Tailwind base layout · MySQL pool · 'hello world' protected route end-to-end
2	Phase 1 — DB Design	Inventory ~64 existing tables · Classify · Draft new tables (RBAC + Job + Equipment first) · Seed scripts · Lock ERD
3	Block 1 — Auth + RBAC	employee_id + password login · JWT + refresh · RBAC middleware (role + granular perm) · Sidebar visibility · Row-level scoping helper · Audit-log helper
4–5	Block 2a — Equipment Master	Equipment list/detail/register · State machine (incl. PENDING_VERIFICATION) · Cal history · Specs
5–6	Block 2b — Job Requests	Multi-section form (T&ME/F&PE; cal/repair/registration) · Draft/submit · Approve/reject · State machine
6–7	Block 2c — Job Cards + PDF	Auto-create on approval · Task checklist + observations · Verify/close → Equipment status update · PDF cert generation
8	Block 3 — Dashboard + Inquiry	Dashboard widgets (KPIs, due alerts, workload) · Inquiry 4-tab search
9	Hardening	Audit coverage check · RBAC e2e test (all 5 roles) · Illegal-transition tests · SQL tuning · Responsive QA
10	Demo Prep + Deploy	Demo data seeded · On-prem deploy · Stakeholder demo · Bug-fix buffer

18.1 Slack / Buffer Strategy

Risk	Buffer Plan
Existing 64-table DB messier than expected	Phase 1 stretches into Week 3; Auth gets compressed
Job Card observations more complex than planned	Cut Inquiry tabs to 2 (job cards + equipment) for demo
PDF formatting takes longer	Ship plain-template PDFs; polish post-internship
RBAC edge cases discovered	Core — never cut. Cut Dashboard widgets instead.

Section 19 — Real-World End-to-End Walk-Through

Tracing a single instrument (Digital Multimeter DMM-2034) through CMCMIS — to make all the architecture concrete.

Step	Actor	Role	Module	Action
1	Engineer Deep	Lab Engineer	Dashboard	Sees DMM-2034 calibration due alert
2	Deep	Lab Engineer	Job Requests	Raises calibration request
3	Lab In-charge	Lab In-charge	Job Requests	Approves → Job Card auto-created
4	Deep (auto-assigned)	Lab Engineer	Job Cards	Completes tasks, enters readings, marks COMPLETE
5	Lab In-charge	Lab In-charge	Job Cards	Verifies + closes → triggers PDF cert generation
6	Anyone (except View-Only)	Any of 4 roles	Equipment	Could register new DMM-2035 tomorrow (PENDING_VERIFICATION)
7	Lab In-charge	Lab In-charge	Equipment	Verifies DMM-2035 → ACTIVE
8	Super Admin	Super Admin	Admin (seed/CLI in MVP)	Promotes Normal User → Lab Engineer
9	View-Only auditor	View-Only	Inquiry	Searches DMM-2034 history; reads everything; edits nothing
10	Super Admin	Super Admin	Audit Log	Reviews every state transition

One instrument, one calibration cycle ≈ 20 DB writes across ~12 tables, 1 PDF cert, ~9 audit rows. This is why the ~70-table schema is the MINIMUM to track this lawfully.

Section 20 — Constraints, Open Items, Quick Recap

20.1 Locked Constraints

#	Constraint	Decision
1	Organization context	ISRO SAC-like defence/space-grade
2	Existing DB	~64 tables; review in Phase 1; never drop in MVP
3	SSO in v1	NO — employee_id login from existing DB; SSO-ready for future
4	Deployment target	Internal on-prem / org private infra
5	File storage	NO — PDFs generated + downloaded only
6	Email / SMTP	NO in v1
7	Redis / cache	NO — MySQL + pagination + pool
8	Backup infrastructure	Out of scope (user handles separately)
9	Mobile / tablet UI	NO — desktop/laptop only; fully responsive within range
10	Barcode / QR	NO
11	PDF generation	YES — pdfkit, server-side, download only
12	Sensitive data	Defence-grade; row-level visibility + secure sessions + limited exports

20.2 Open Items Awaiting Your Call

- Lock the 7 small stack additions (cookie-parser, compression, CSRF, table lib, tailwind-forms, testing, swagger).
- Confirm proposed folder structure (Section 15).
- Confirm coding conventions (Section 16).
- Hand over phpMyAdmin export of existing ~64 tables to start Phase 1 DB inventory.

20.3 Big Quick Recap (Print-and-Pin)

Topic	Locked Decision
Roles	5 only — Super Admin, Lab In-charge, Lab Engineer, Normal, View-Only (Admin role DELETED)
equipment:create	Open to ALL roles except View-Only
Equipment lifecycle	Starts at PENDING_VERIFICATION → ACTIVE (BR-EQP-10)
Per-user role count	Exactly ONE primary role (BR-RBAC-02)

Super Admin seed	≥ 2 via SUPER_ADMIN_EMPLOYEE_IDS env var
Session model	15-min JWT · 60-min idle · 7-day refresh (concentric envelopes)
Tech stack	React 18+Vite+TW+Zustand+RQ+Axios+RHF+Zod / Express 4+mysql2+Zod+JWT+bcryptjs+Pino+PDFKit+Helmet+PM2
Symmetry wins	zod schemas + dayjs date math shared across FE/BE
Audit retention	Indefinite (until user specifies)
API base	/api/v1/... from day 1
Timeline	10 weeks (solo dev + AI pair), MVP first, full go-live after stakeholder sign-off
DB target	~70 tables (existing 64 reviewed + new added)
Bottom line	Industry-grade, defence-grade context, demo-ready MVP in 10 weeks. Josh: MAXED.

END OF DOCUMENT — v3 master plan locked. Next step: confirm small additions + hand over existing DB export → enter Phase 1.

*******IMPORTANT*******

Section 14 — Decisions I Need You to Confirm

#	Decision	My Recommendation	Confirm?
D1	JavaScript or TypeScript?	JavaScript + JSDoc + Zod	YES
D2	ORM vs Raw SQL?	Raw SQL + Repository	YES

#	Decision	My Recommendation	Confirm?
		pattern	
D3	Add React Query?	Yes (saves massive FE code)	☐ YES
D4	Zustand for state?	Yes (over Redux)	☐ YES
D5	pdfkit for PDFs?	Yes (over Puppeteer)	☐ YES
D6	Pino for logging?	Yes (over Winston)	☐ YES
D7	Repository pattern in BE?	Yes (layer routes → controllers → services → repos)	☐ YES
D8	Feature-based FE folders?	Yes (over layer-based)	☐ YES
D9	Nginx reverse proxy in production?	Yes (standard)	☐ YES
D10 to	New equipment defaults PENDING_VERIFICATION?	Yes (safety from Section 0)	☐ YES

⚙️ Section 9 — Phase 2 Decisions Update

Tiny update to one decision from last message's Section 14:

#	Decision	Status
D11 (new)	Seed at least 2 Super Admin employee IDs in SUPER_ADMIN_EMPLOYEE_IDS env var	Recommended ☒

ANSWER-----→yes we have to seed 2 super admin employee ID I will provide you tomorrow this 2 ids while developing or design database schemas.

What I need from you to begin Phase 3:

- Export the existing DB schema (just SHOW CREATE TABLE outputs for all 64 tables, or mysqldump --no-data).

ANSWER-----→ tomorrow at early morning I will provide this details please keep it tomorrow.

- A short note on which existing tables you know are **definitely still used**, which are **probably dead**, and which you're **unsure** about. **ANSWER-----→ tomorrow at early morning I will provide this details please keep it tomorrow.**

ONCE I WILL PROVIDE YOU TOMMOROW AT EARLY MORNING LIKE existing database schemas or tables and than we will edit and design new schemas from scratch or from the basics for the database. The deepest, most important phase of all.

Energy level: locked. Discipline level: locked. Let's keep moving. 🚀

☑ Section 11 — Confirmation Points

Confirm?

Five roles final: Super Admin, Lab In-charge, Lab
C1 Engineer, Normal User, View-Only

ANSWER-----→ YES

Master Data Management remains Phase 2, accessible
C2 by Super Admin only

**ANSWER-----→ I WILL PROVIDE YOU
INSTRUCTIONS FOR THE SAME WHILE WE DEVELOP IT.**

Confirm?

C3 Lookup data (vendors, equipment types, divisions) will be seeded in Week 2 and edited via phpMyAdmin during MVP

ANSWER-----→YES

Bootstrap with at least 2 Super Admin employee IDs

C4 (you'll provide them when we get to seeding)

ANSWER-----→YES

Equipment verification (PENDING → ACTIVE) belongs to

C5 Lab In-charge + Super Admin

ANSWER-----→YES

Locked in. 5 roles. Clean model. Moving.  